

ZacTrades Security Work Report

Summary of completed hardening work, edited files, verification results, and remaining actions. Generated 2026-07-30 for /Users/yassine/Downloads/mentor-market-flow-main-1.

COMPLETED	Removed insecure local payment confirmation paths and raw card collection from checkout.
ADDED	NOWPayments IPN endpoint with HMAC verification, event idempotency, and amount/currency validation.
STILL TODO	Run the Supabase migration, rotate pasted NOWPayments secrets, configure production env vars, and add a card-provider webhook.

1. Steps Completed

- Inspected the project architecture, payment flow, Supabase schema, checkout UI, server entry, and environment handling.
- Created SECURITY_AUDIT.md before making security changes, documenting critical and high-priority findings.
- Removed local paid-access fallback behavior so the browser can no longer cause paid access without provider confirmation.
- Removed raw card number, expiry, and CVC inputs from the checkout dialog and replaced them with a hosted-checkout notice.
- Changed checkout server functions so the server computes product price and duration from trusted product records instead of browser-submitted labels.
- Added a NOWPayments IPN endpoint at /api/nowpayments/ipn with HMAC SHA-512 verification and idempotent event storage.
- Added a Supabase migration for payment_webhook_events, provider checkout uniqueness, and revoking local payment confirmation functions.
- Added baseline browser security headers, including CSP, HSTS, Referrer-Policy, X-Content-Type-Options, and Permissions-Policy.
- Hardened .env handling and documented which variables are browser-safe versus server-only.
- Added a PDF upload size limit and randomized uploaded PDF object names.
- Ran formatter, build, lint, dependency audit, and frontend secret scans.

2. Verification Results

Check	Result
npm run build	Passed. Client and SSR production builds completed successfully.
npm run lint	Passed with 6 existing Fast Refresh warnings in reusable UI helper files. No lint errors.
npm audit --omit=dev	Passed after safe npm audit fix. Final result: 0 vulnerabilities.
Frontend secret scan	No matches for server-only secret names or previously pasted secret fragments in dist/client.
Insecure checkout scan	No old local_paid, paymentReference, setCard, setCvc, raw card-number, or crypto-reference confirmation paths found. Only safe explanatory CVC text remains.

3. Files Edited

File	What changed
.env.example	Documented browser-safe and server-only environment variables, including NOWPayments callback settings.
.gitignore	Added protection for .env and .env.* files while keeping .env.example tracked.
package-lock.json	Updated by npm audit fix to resolve production dependency vulnerabilities.
src/components/site/AuthDialog.tsx	Formatted by Prettier as part of lint cleanup from previous UI edits.
src/components/site/CheckoutDialog.tsx	Removed raw card fields and local paid success branches; sends only product slugs/payment method to server.
src/lib/payment-server.ts	Reworked checkout authority, provider checkout creation, NOWPayments invoice creation, and IPN webhook handling.
src/routes/admin.tsx	Added PDF upload size limit/randomized upload path and formatted admin changes.
src/routes/blog.tsx	Formatted by Prettier after earlier blog route changes.
src/routes/blog_.\$slug.tsx	Formatted by Prettier after earlier blog detail/PDF reader changes.
src/routes/live-trading.tsx	Formatted by Prettier after earlier live-trading page changes.
src/routes/news.tsx	Formatted by Prettier after earlier news-page changes.
src/server.ts	Added security headers and /api/nowpayments/ipn routing.
supabase/auth-schema.sql	Appended security hardening SQL block for new database installs.
supabase/migrations/202607300001_security_hardening.sql	New migration for webhook events, unique indexes, and revoking local payment confirmation functions.
SECURITY_AUDIT.md	New audit report with findings, fixes, verification, and remaining risks.
SECURITY_IMPLEMENTATION.md	New implementation notes with payment design, env vars, manual actions, and deployment checklist.

4. Payment Security Design

Card payments

- The site no longer collects card number, expiry, or CVC. This keeps the application out of the raw card-data path.
- A card checkout can only continue through a hosted provider URL configured server-side.
- Paid access should be granted only after the chosen card provider sends a verified webhook.

Crypto payments with NOWPayments

- The server creates a hosted NOWPayments invoice using trusted server-side product price and metadata.
- NOWPayments IPN events are accepted only with a valid x-nowpayments-sig HMAC signature.
- The webhook stores each event uniquely before fulfillment to protect against duplicate delivery.
- The webhook checks local checkout reference, expected amount, and expected USD currency before marking access paid.

5. Database Changes To Run

Run this file in the Supabase SQL editor:

supabase/migrations/202607300001_security_hardening.sql

- Creates public.payment_webhook_events for provider webhook idempotency.
- Adds unique provider checkout indexes on membership, live trading, and news subscription tables.
- Revokes execute permission on local_confirm_local_* functions from public, anon, and authenticated roles.
- If unique indexes fail, clean duplicate provider_checkout_id records first, then rerun the migration.

6. What Still Should Be Edited After

Priority	Action
Required	Rotate the NOWPayments API key and IPN secret that were pasted in chat before production.
Required	Add the rotated server-only secrets to hosting environment variables, not to git or VITE_* variables.
Required	Configure NOWPayments IPN callback URL to https://your-domain.com/api/nowpayments/ipn.
Required	Run the Supabase security hardening migration on the live database.
Required	Test one low-value or sandbox crypto payment and confirm access changes only after the IPN arrives.
Important	Choose the real card-payment provider and add its signed webhook before enabling automated card access.
Important	Decide whether blog PDFs are public or private. If private, move the bucket private and use signed URLs.
Important	Move sensitive admin actions, such as manual paid access and role edits, to audited server functions.
Optional	Resolve existing Fast Refresh lint warnings in reusable UI files if you want completely warning-free lint output.

7. Safe Deployment Checklist

- Confirm npm run build passes before deployment.
- Confirm npm run lint has no errors.
- Confirm npm audit --omit=dev reports zero vulnerabilities.
- Confirm dist/client does not contain server-only secret names or secret fragments.
- Apply the Supabase migration before testing paid access.
- Set NOWPayments and Supabase service-role variables as server-only hosting secrets.
- Make sure /api/nowpayments/ipn is publicly reachable over HTTPS.
- Do not commit .env, .env.local, dist/server/.dev.vars, or any real provider secrets.

Report files in the project: SECURITY_AUDIT.md and SECURITY_IMPLEMENTATION.md contain the detailed written record behind this PDF.